МИНИСТЕРСТВО ЦИФРОВЫХ ТЕХНОЛОГИЙ РЕСПУБЛИКИ УЗБЕКИСТАН
ТАШКЕНТСКИЙ УНИВЕРСИТЕТ ИНФОРМАЦИОННЫХ ТЕХНОЛОГИЙ
имени Мухаммада ал-Хоразмий

Дисциплина: «Введение в программную инженерию»

ПРАКТИЧЕСКАЯ РАБОТА № 10

Инжиниринг безопасности: случаи злоупотребления, модель угроз и требования безопасности

Вариант 19: разработка АРМ администратора салона красоты

Выполнил: **Тожикулов Асилбек**
Группа: **M320-24**
Вариант: **19**
Принял: _____

Ташкент, 2026

1. Тема практической работы

Инжиниринг безопасности: случаи злоупотребления, модель угроз и требования безопасности.

Цель работы: закрепление знаний по теоретическим сведениям. Научиться выявлять активы и угрозы безопасности программной системы, описывать случаи злоупотребления, строить модель угроз по STRIDE, оценивать и приоритизировать риски безопасности, выбирать меры смягчения угроз и формулировать проверяемые требования безопасности.

2. Описание проекта и использованные результаты

BeautyDesk – веб-система (АРМ) для администраторов сети из трёх салонов красоты в Ташкенте. Она ведёт базу клиентов, графики мастеров и журнал записи без накладок, принимает оплату (наличные, карты UzCard/Humo, Payme, Click), рассылает напоминания через SMS и Telegram, считает материалы и зарплату мастеров. Пользователи – администраторы, мастера, управляющий и владелец сети. Сервер приложений и база данных размещены в дата-центре в Ташкенте.

С точки зрения безопасности система интересна тем, что хранит персональные данные клиентов и проводит деньги, а работают с ней сотрудники с разным уровнем доверия. Поэтому угрозы рассматриваются не только снаружи, но и изнутри салона.

Таблица 1 – Использованные результаты предыдущих работ

Работа	Что использовано в этой работе
ПР 5	варианты использования UC-01…UC-13 (основные – UC-01 «Записать клиента», UC-02 «Найти клиента по телефону», UC-04 «Провести оплату визита», UC-05 «Открыть/закрыть смену кассы»), роли пользователей, требование NFR-03 (HTTPS, хеширование паролей, доступ по ролям, журнал действий) и NFR-04 (хранение персональных данных в Узбекистане)
ПР 6	модульный монолит и подсистемы «Клиенты», «Журнал записи», «Касса», «Уведомления», «Отчёты»; диаграмма развёртывания: Nginx + Gunicorn + Celery на сервере приложений, отдельный сервер PostgreSQL и Redis, наружу открыт только порт 443; внешние системы Payme, Click, SMS-шлюз, Telegram Bot API
ПР 9	целевая характеристика «Защищённость» и требование QR-07 (0 обращений к данным вне роли, OWASP ZAP без находок High), QR-03 (резервные копии), компромисс №3 (2FA только для владельца и управляющего), мини-план SQA – куда будут встроены проверки безопасности

3. Активы и злоумышленники

3.1. Активы системы

Свойства безопасности обозначены буквами: **К** – конфиденциальность, **Ц** – целостность, **Д** – доступность, **П** – подотчётность (возможность установить, кто выполнил действие).

Таблица 2 – Активы системы BeautyDesk

№	Актив	Где хранится / обрабатывается	Свойства	Последствия ущерба
A1	База клиентов: имя, телефон, история визитов, заметки	D1 PostgreSQL, подсистема «Клиенты», экран поиска в SPA	К, Ц	утечка персональных данных, нарушение закона о персональных данных, клиенты уходят к конкуренту или к мастеру «на дом»
A2	Журнал записи и графики мастеров	D1, кэш календаря в D2 Redis, подсистема «Журнал записи»	Ц, Д	двойные записи и пустые окна, клиенты приходят зря, прямые потери выручки
A3	Платёжные операции и кассовые смены	D1, подсистема «Касса», обмен с Payme/Click	Ц, П	хищение наличных, расхождение кассы, споры с клиентами и налоговыми органами
A4	Учётные записи и сессии пользователей	D1 (хеши паролей, роли), D2 (сессии)	К, Ц	захват учётной записи и действия от чужого имени
A5	Секреты интеграций: ключи Payme/Click, токен Telegram-бота, ключ SMS-шлюза, пароль БД	переменные окружения сервера приложений	К	подделка платежей, рассылка от имени салона, прямой доступ к базе
A6	Отчёты, выручка, зарплата мастеров	D1, подсистема «Отчёты»	К	конфликты в коллективе, раскрытие коммерческой информации
A7	Резервные копии базы	D3 хранилище копий	К, Д	утечка всей базы сразу; при порче копий – невозможность восстановления
A8	Журнал аудита действий	D1, отдельная таблица только для добавления	Ц, П	невозможно разобрать инцидент и найти виновного

3.2. Возможные злоумышленники

Таблица 3 – Перечень возможных злоумышленников

Злоумышленник	Мотив	Возможности	Цели (активы)
31. Внешний злоумышленник	деньги, продажа баз, «из интереса»; автоматические боты	доступ из интернета к странице входа и API, перебор паролей, фишинг, сканирование уязвимостей	A4, A1, A5

Злоумышленник	Мотив	Возможности	Цели (активы)
32. Недобросовестный администратор	присвоить наличные, унести базу при увольнении	законный доступ к журналу записи, клиентам и кассе своего салона	A3, A1, A8
33. Недобросовестный мастер	переманить клиентов к себе, узнать заработок коллег	доступ к своему расписанию со смартфона, может пытаться подменять параметры запросов	A1, A6
34. Бывший сотрудник	месть или работа у конкурента	знает процессы, может сохранить пароль или доступ к Telegram-чату	A1, A4
35. Злонамеренный «клиент» или конкурент	сорвать работу салона	ложные записи и спам через будущий Telegram-бот, DoS на публичные адреса	A2

4. Случаи злоупотребления

Случаи злоупотребления (misuse cases) выбраны для трёх основных вариантов использования из ПР 5, на которых держатся деньги и данные салона: поиск клиента, оплата визита и вход в систему перед записью. На диаграмме злоумышленники и случаи злоупотребления показаны чёрным, связь «угрожает» идёт от случая злоупотребления к обычному варианту использования, связь «смягчает» – от защитного варианта использования к случаю злоупотребления.

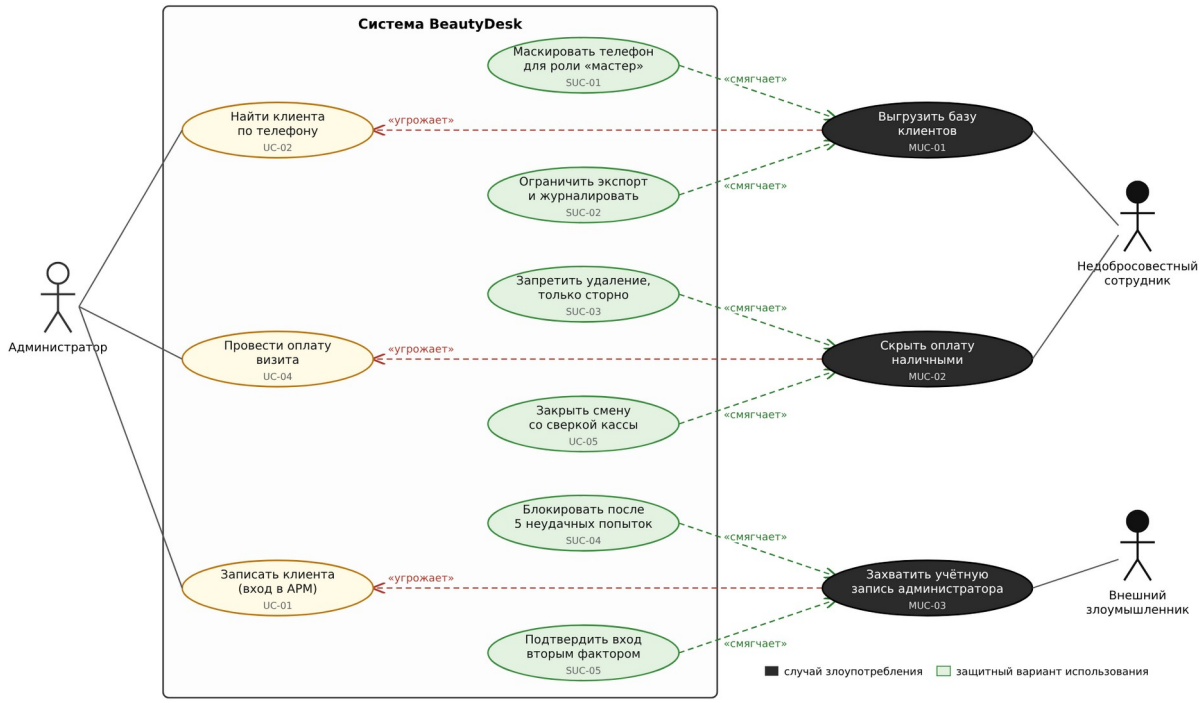


Рисунок 1 – Диаграмма случаев злоупотребления

Таблица 4 – Случай злоупотребления MUC-01

Поле	Описание
Идентификатор	MUC-01 «Выгрузить базу клиентов»
Злоумышленник	33 недобросовестный мастер, 32 администратор перед увольнением
Угрожает	UC-02 «Найти клиента по телефону»
Предусловие	у злоумышленника есть действующая учётная запись
Сценарий злоупотребления	1) злоумышленник открывает поиск или карточку клиента; 2) перебирает клиентов (через интерфейс или подменяя id в запросах к API) и копирует имена и телефоны; 3) уносит список и предлагает клиентам услуги в другом месте
Альтернатива	1a) администратор пытается сделать выгрузку клиентов в Excel
Последствия	утечка A1, потеря клиентов, нарушение законодательства о персональных данных
Смягчающие варианты	SUC-01 «Маскировать телефон для роли „мастер“» (мастер видит только +998 90 * 45 и только своих клиентов); SUC-02 «Ограничить экспорт и журналировать» (выгрузка – только управляющему, каждый просмотр карточки пишется в журнал, при > 50 карточек за час – уведомление управляющему)
Угрозы STRIDE	T04, T06

Таблица 5 – Случай злоупотребления MUC-02

Поле	Описание
Идентификатор	MUC-02 «Скрыть оплату наличными»
Злоумышленник	32 недобросовестный администратор
Угрожает	UC-04 «Провести оплату визита»
Предусловие	клиент оплатил визит наличными; администратор имеет доступ к кассе
Сценарий злоупотребления	1) администратор отмечает визит как «не пришёл» или удаляет проведённую оплату; 2) оставляет наличные себе; 3) при закрытии смены расхождения нет, потому что в системе оплаты как будто не было
Альтернатива	1a) администратор уменьшает сумму оплаты задним числом или оформляет скидку без основания
Последствия	хищение денег салона (A3), искажённые отчёты и зарплата мастера, мастер не получает свой процент
Смягчающие варианты	SUC-03 «Запретить удаление, только сторно» (исправление – отдельной операцией с причиной и подтверждением управляющего, всё пишется в журнал аудита); UC-05 «Закрыть смену со сверкой кассы» (сверка с отметками мастеров об оказанных услугах)
Угрозы STRIDE	T03, T05

Таблица 6 – Случай злоупотребления MUC-03

Поле	Описание
Идентификатор	MUC-03 «Захватить учётную запись администратора»
Злоумышленник	31 внешний злоумышленник, 34 бывший сотрудник
Угрожает	UC-01 «Записать клиента» и все функции, доступные после входа

Поле	Описание
Предусловие	страница входа доступна из интернета
Сценарий злоупотребления	1) злоумышленник узнаёт логин (обычно имя администратора); 2) перебирает распространённые пароли или использует пароль, сохранённый бывшим сотрудником; 3) входит в систему и получает доступ к клиентам, записям и кассе
Альтернатива	2а) пароль получен через фишинговое сообщение в Telegram «от техподдержки»
Последствия	утечка A1, порча журнала записи A2, действия от имени администратора
Смягчающие варианты	SUC-04 «Блокировать после 5 неудачных попыток» (блокировка на 15 мин и уведомление управляющему); SUC-05 «Подтвердить вход вторым фактором» (для управляющего и владельца – обязательно, для администраторов – при входе с нового устройства); при увольнении учётная запись отключается в тот же день
Угрозы STRIDE	T01, T09

5. DFD, поверхность атаки и модель угроз STRIDE

5.1. Диаграмма потоков данных

DFD построена по диаграмме развёртывания из ПР 6. Внешние сущности показаны прямоугольниками, процессы – кругами, хранилища – открытыми прямоугольниками, границы доверия (ГД) – красным пунктиром. Каждый поток, пересекающий границу доверия, – место, где нужна проверка входных данных и аутентификация.

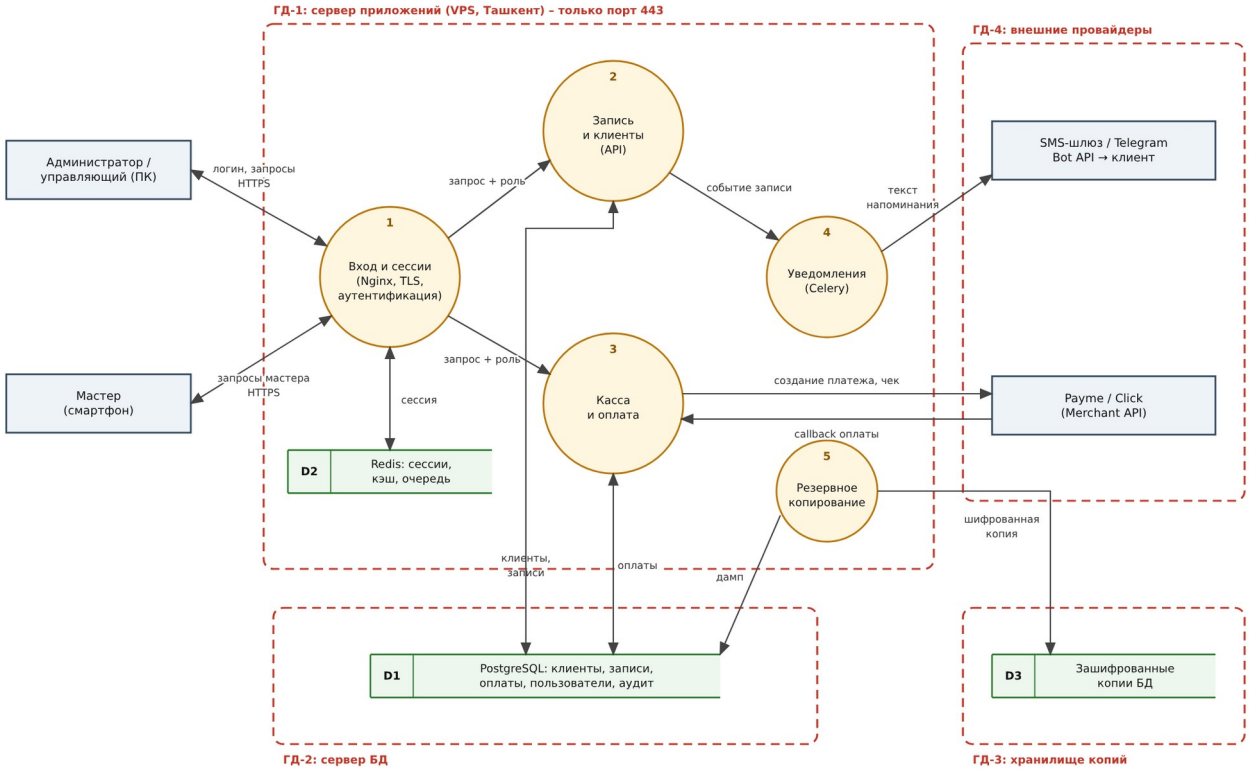


Рисунок 2 – DFD системы BeautyDesk с границами доверия

5.2. Точки входа и сокращение поверхности атаки

Таблица 7 – Точки входа и меры сокращения поверхности атаки

№	Точка входа	Кто может обратиться	Меры сокращения поверхности атаки
ТВ-1	страница входа /login	любой пользователь интернета	ограничение частоты запросов; блокировка после 5 ошибок; общий текст ошибки без подсказки «нет такого логина»
ТВ-2	REST API /api/* (SPA администратора и мастера)	аутентифицированные пользователи	удалить неиспользуемые методы; проверка роли и салона на каждом запросе; мастеру доступен только узкий набор методов /api/master/*
ТВ-3	callback /api/pay/callback от Payme и Click	платёжные провайдеры (и любой, кто знает адрес)	приём только с IP-адресов провайдеров, проверка подписи/ключа мерчанта, сверка суммы с заказом в БД
ТВ-4	импорт клиентов из Excel	управляющий	нужен только один раз при переходе с тетради: включить на время миграции и затем отключить; только .xlsx до 5 МБ
ТВ-5	панель Django /admin	разработчики	в продакшене отключить; при необходимости – только через VPN
ТВ-6	SSH к серверам	разработчики, хостинг	вход только по ключам, root запрещён, доступ только с IP офиса или через VPN
ТВ-7	webhook Telegram-бота	Telegram и клиенты	не публиковать до инкремента 3, когда появится бот клиента; секретный токен в адресе webhook

Главная мера сокращения поверхности атаки – «не открывать лишнего»: базы данных и Redis недоступны из интернета, наружу открыт только порт 443, временные и служебные входы (ТВ-4, ТВ-5, ТВ-7) в рабочей системе выключены.

5.3. Модель угроз STRIDE

Угрозы определены по элементам DFD с помощью STRIDE: **S** – подмена (Spoofing), **T** – изменение (Tampering), **R** – отказ от действий (Repudiation), **I** – раскрытие информации (Information disclosure), **D** – отказ в обслуживании (Denial of service), **E** – повышение привилегий (Elevation of privilege). Выделено 12 угроз во всех шести категориях.

Таблица 8 – Модель угроз STRIDE

ID	Кат.	Угроза	Элемент DFD	Актив
T01	S	Подбор или кража пароля администратора и вход от его имени (MUC-03)	процесс 1, ТВ-1	A4, A1
T02	S	Поддельный callback «оплата прошла» от имени Payme/Click: визит отмечается оплаченным без денег	поток Payme → 3, ТВ-3	A3
T03	T	Администратор удаляет или уменьшает оплату наличными задним числом (MUC-02)	процесс 3, D1	A3
T04	T	Изменение чужой записи через API подменой идентификатора записи или мастера (IDOR)	процесс 2, ТВ-2	A2

ID	Кат.	Угроза	Элемент DFD	Актив
T05	R	Сотрудник отрицает, что отменил запись или изменил сумму, так как действия не фиксируются	процессы 2, 3, D1	A8, A3
T06	I	Мастер просматривает телефоны и историю чужих клиентов, перебирая id в API (MUC-01)	процесс 2, ТВ-2	A1
T07	I	Утечка резервной копии из внешнего хранилища	поток 5 → D3, D3	A7, A1
T08	I	Утечка секретов (ключ Payme, токен бота) из репозитория или конфигурации	процессы 3, 4	A5
T09	D	Массовые запросы к /login и API в часы пик – администраторы не могут работать	процесс 1, ТВ-1, ТВ-2	A2
T10	D	Блокировка SMS-аккаунта салона из-за массовой рассылки или переполнения очереди	процесс 4, D2	A2
T11	E	Мастер или администратор получает права управляющего, подменив роль в запросе	процессы 1, 2	A4, A6
T12	E	Вход на сервер через /admin или SSH со слабым паролем – полный контроль над системой	ТВ-5, ТВ-6, ГД-1	все

6. Оценка рисков, меры и требования безопасности

6.1. Оценка и приоритизация рисков

Вероятность (P) и ущерб (I) оценены по шкале 1–3 (1 – низкий, 2 – средний, 3 – высокий). Уровень риска R = P × I: 6–9 – высокий, 3–4 – средний, 1–2 – низкий. Вероятность оценивалась с учётом того, кто может реализовать угрозу (таблица 3) и насколько это просто, ущерб – по последствиям для актива (таблица 2).

Таблица 9 – Оценка и приоритизация рисков

№	ID	Угроза (кратко)	P	I	R	Уровень
1	T01	подбор пароля администратора	3	3	9	высокий
2	T06	мастер видит чужих клиентов	3	3	9	высокий
3	T03	удаление оплаты наличными	3	2	6	высокий
4	T02	поддельный callback оплаты	2	3	6	высокий
5	T08	утечка секретов интеграций	2	3	6	высокий
6	T12	вход на сервер через /admin или SSH	2	3	6	высокий
7	T04	изменение чужой записи (IDOR)	2	2	4	средний
8	T05	отказ от действий без журнала	2	2	4	средний
9	T09	отказ в обслуживании в часы пик	2	2	4	средний
10	T07	утечка резервной копии	1	3	3	средний
11	T11	подмена роли в запросе	1	3	3	средний
12	T10	блокировка SMS-аккаунта	1	2	2	низкий

При одинаковом R выше ставилась угроза с большей вероятностью: T01 и T06 реализуются без особых навыков, поэтому они первые. T03 поставлена выше T02, потому что совершить её может любой администратор, а поддельный callback требует знания адреса и формата API.



Рисунок 3 – Матрица рисков

6.2. Реакция на угрозы и контрмеры

Для каждой угрозы выбрана одна из реакций: **снизить** (ввести контрмеры), **устранить** (убрать причину, например отключить функцию), **передать** (переложить на третью сторону) или **принять** (сознательно оставить с наблюдением).

Таблица 10 – Реакция на угрозы и контрмеры

ID	Реакция	Контрмеры	Требование
T01	снизить	блокировка после 5 ошибок на 15 мин, ограничение частоты входа, пароль ≥ 10 символов, 2FA для управляющего и владельца, отключение учётной записи при увольнении	SR-01, SR-07
T06	снизить	проверка на сервере, что клиент относится к записям мастера; маскирование телефона; журнал просмотров и предупреждение при массовом просмотре	SR-02, SR-05
T03	снизить	запрет удаления оплат, только сторно с причиной и подтверждением управляющего; сверка смены с отметками мастеров	SR-04, SR-05
T02	снизить	приём callback только с IP провайдеров, проверка подписи/ключа, сверка суммы и номера заказа, повторный запрос статуса платежа	SR-03
T08	снизить	секреты только в переменных окружения сервера, сканер секретов в CI, смена ключей при уходе сотрудника с доступом	SR-06
T12	устранить	отключить /admin в продакшене, SSH только по ключам и через VPN, наружу только порт 443	SR-09
T04	снизить	проверка принадлежности объекта салону и пользователю в каждом методе API	SR-02
T05	снизить	журнал аудита всех изменений записей, оплат и ролей, недоступный для изменения	SR-05
T09	снизить + передать	ограничение частоты запросов в Nginx; защита от DDoS на стороне хостинг-провайдера по договору	SR-07

ID	Реакция	Контрмеры	Требование
T07	снизить	шифрование копий до отправки, отдельный ключ доступа к хранилищу у одного ответственного	SR-08
T11	снизить	роль берётся только из сессии на сервере, никогда из параметров запроса; тесты матрицы ролей	SR-02
T10	принять	низкий риск; лимит отправки в Celery (не более 1 сообщения клиенту за 12 ч), контроль баланса SMS-шлюза управляющим	–

6.3. Требования безопасности

Требования сформулированы так, чтобы их можно было проверить тестом или осмотром. Вид требования: **ФБ** – функциональное требование безопасности (механизм защиты в системе), **НФ** – нефункциональное ограничение, **ПР** – процессное требование к разработке и эксплуатации.

Таблица 11 – Требования безопасности

ID	Требование	Вид	Угрозы	Способ проверки
SR-01	После 5 неудачных попыток входа подряд учётная запись блокируется на 15 мин, управляющий получает уведомление. Пароли – не короче 10 символов, хранятся только в виде хеша (Argon2). Для ролей «управляющий» и «владелец» вход требует второго фактора (TOTP)	ФБ	T01	автотест: 6-я попытка возвращает блокировку; проверка, что в БД нет паролей в открытом виде; ручной тест входа с 2FA
SR-02	Каждый метод API проверяет на сервере роль пользователя (из сессии) и принадлежность объекта его салону; мастер получает только свои записи, телефон клиента для него маскируется	ФБ	T04, T06, T11	автотесты по матрице ролей (QR-07 из ПР 9); ручной тест подмены id и роли в запросах
SR-03	Уведомление об оплате принимается только с IP-адресов Payme/Click и с правильной подписью; сумма и номер заказа сверяются с записью в БД, иначе запрос отклоняется и пишется в журнал	ФБ	T02	интеграционный тест с поддельным callback – отклонён; проверка в песочнице Payme и Click
SR-04	Проведённую оплату нельзя удалить или изменить; исправление выполняется только сторнирующей операцией с указанием причины и подтверждением управляющего	ФБ	T03	автотест: запрос на удаление оплаты возвращает отказ; сценарий сторно в приёмочном тесте
SR-05	Создание, изменение и отмена записей, операции кассы, изменения ролей и выгрузки фиксируются в журнале аудита (кто, когда, было/стало, IP). Журнал доступен только для чтения управляющему и хранится не менее 1 года	ФБ	T03, T05, T06	автотест: после изменения записи появляется строка аудита; попытка изменить журнал через API отклоняется

ID	Требование	Вид	Угрозы	Способ проверки
SR-06	Ключи и токены интеграций хранятся только в переменных окружения сервера и не попадают в репозиторий; в CI работает сканер секретов; при увольнении сотрудника с доступом ключи меняются в течение 1 дня	ПР	T08	отчёт gitleaks в CI без находок; аудит чек-листа увольнения
SR-07	Не более 10 попыток входа в минуту с одного IP и 300 запросов к API в минуту на пользователя; превышение – ответ 429. Защита от DDoS обеспечивается хостингом по договору	НФ	T01, T09	нагрузочный тест Locust: при превышении лимита – 429, обычная работа не нарушается; пункт договора хостинга
SR-08	Резервные копии шифруются (AES-256) до отправки в хранилище; ключ расшифровки хранится отдельно от копий и доступен только ответственному	НФ	T07	попытка открыть копию без ключа; ежемесячное учебное восстановление (QR-03)
SR-09	Наружу открыт только порт 443; SSH – только по ключам, с IP офиса или через VPN, вход root запрещён; панель /admin в продакшене отключена	НФ	T12	сканирование портов nmap снаружи; проверка конфигурации sshd; запрос к /admin возвращает 404

Проверка покрытия. Все шесть угроз высокого риска (T01, T06, T03, T02, T08, T12) и все пять угроз среднего риска (T04, T05, T09, T07, T11) закрыты хотя бы одним требованием; T01, T03 и T06 – двумя. Угроза низкого риска T10 принята. Проверки SR-01…SR-09 включаются в мини-план SQA из ПР 9: автотесты выполняются в CI при каждом pull request, сканирование портов и OWASP ZAP – перед выпуском каждого инкремента.

7. Вывод

В работе выполнен инжиниринг безопасности для системы BeautyDesk на основе результатов ПР 5, 6 и 9. Выявлено 8 активов, главные из которых – база клиентов, платёжные операции и учётные записи, и 5 типов злоумышленников. Важный вывод для этой системы: значительная часть угроз исходит не от хакеров, а от своих сотрудников – администратора с доступом к кассе и мастера, заинтересованного в клиентской базе.

Описаны три случая злоупотребления (выгрузка базы клиентов, сокрытие оплаты наличными, захват учётной записи) и построена их UML-диаграмма с защитными вариантами использования. По DFD с четырьмя границами доверия определены 7 точек входа и меры сокращения поверхности атаки, составлена модель угроз STRIDE из 12 угроз во всех шести категориях.

Оценка рисков выделила 6 угроз высокого, 5 среднего и 1 низкого уровня. Для каждой выбрана реакция и контрмеры, сформулировано 9 проверяемых требований безопасности SR-01…SR-09, которые закрывают все угрозы высокого и среднего

риска. Я понял, что требования безопасности лучше выводить из конкретных угроз: тогда каждое требование понятно зачем нужно и как его проверить.